

Reverse-Shell

Beshir Said

Part 1:

- a) After I uploaded my saidb-webshell.php file, I went to my MAC terminal and visited <http://danger.jeffondich.com/uploadedimages/saidb-webshell.php?command=whoami> and got the result of [www.data](#). This is the default user that web servers on Ubuntu, Apache, nginx, etc.
- b) The <pre> tag is a formatting tool that presents and preserves the text exactly as written in the HTML file so it's readable for the attacker. Without it, the browser will treat the output as normal HTML and could line break and mess up the formatting.

Part 2:

- a) The directory: /var/www/danger.jeffondich.com/uploadedimages
- b) I used the getent passwd command and got a long list of user accounts but there are 3 human users : Jeff, Bullwinkle, usr. They are the only ones with home directories so I just assumed that this means they are an interactive user. I think the rest are system or service accounts.
- c) Yes, it contains one line for each account that gives all account info. For example, here is one line: www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
- d) No, I don't have access to the /etc/shadow. It seems that it is only readable by root and stores hashed passwords which is probably why the file is protected.
- e) I found 3 files:
 - /var/www/danger.jeffondich.com/secrets/config/secrets.config: This contained a message that gives a master password for everything.
 - /var/www/[danger.jeffondich.com/secrets/kindasecret.txt](#): This contained a frog by Joan Stark
 - /var/www/[danger.jeffondich.com/youwontfindthiswithgobuster/secret.txt](#): This contained 2 owls.

Part 4:

- a) I used the ifconfig command and got 192.168.64.2 as the IP for Kali VM.
- b) I used the ifconfig -a command and got 192.168.64.1 as the IP for my host OS. I should use this IP to communicate with Kali. You can check connectivity by pinging the Kali IP and curling the websell. This would verify that both can talk to each other.
- c) I used port 6666 , so I ran nc -l -p 6666 on the host OS.
- d) I started a listener on port 6666 on my host. Then I visited the webshell URL on Kali that ran the bash command. This made Kali open a TCP connection back to my listener and gave me an interactive shell.
- e) I know it is Kali because I confirmed using the hostname command, I got Kali.

- f) The % codes in the URL are used to denote specific characters since URLs can't include spaces, they are encoded. There are some for punctuations, special characters, and spaces. For example, %20 is a space and %3F is a question mark.
- g) To start the reverse shell, you want to start a nc listener on the host OS at a chosen port. Then, from the target's webshell run the bash command that opens a TCP connection back to that host listener. When Kali connects to your listener you will have an interactive shell on Kali. To verify, use commands like whoami or hostname in the listener and the responses will show the target's username and hostname, verifying the shell is on the target.